POOJA KIRAN | SECURITY ENGINEERING

# Static Security Analysis of AWS IAM Policies for AI Workload Identities

Detecting Excessive Privilege and Identity-Pivot Risks Before Deployment

Source inventory: 2a7344a0c3ac99864f3d7e7025d8ea89db183c79

Test snapshot: 229605c9c53068f4c0d7116d67554d19afe30183

CI run 37170669504 | initiated 2026-10-04 UTC | MIT

https://github.com/poojakira/aws-agent-identity-guard

**240**
tests passed in cited CI

**3**
disabled separate-rule-API tests skipped

**24 + 1**
offline policy/trust rules + optional role-metadata check

**0.8397 ms**
p95 on 500 synthetic policies in cited CI

## CONTRIBUTION

- IAM policy and trust analysis emits text, JSON and SARIF findings, with a separate permission-boundary check when optional role metadata is supplied.

## IMPLEMENTED METHOD

- 1. Parse offline policy and trust documents; use separately configured optional inventory for role metadata.
- 2. Classify statements and trust-policy structure.
- 3. Apply 24 offline policy/trust rules; apply the separate permission-boundary check only when role metadata is available.
- 4. Emit findings with stable rule IDs and severity.
- 5. Return CI-friendly exit codes and optional SARIF.

## LIMITATIONS AND EVIDENCE BOUNDARY

- Static findings do not prove complete effective permissions or all account-wide escalation paths.
- The tool is not a runtime authorization proxy; no production latency or reliability SLO is established.
- Optional AWS inventory needs separately configured operator credentials; this audit performed no live AWS calls.

## SCOPED EVIDENCE

- Cited Python 3.12 CI: 243 collected, 240 passed, 3 skipped, no errors/failures. Skips are hard-disabled separate-rule-API tests, not a missing AWS credential requirement.
- Source implements 21 identity-policy rules and 3 trust-policy rules offline. AIG-PB001 is a separate optional role-metadata permission-boundary check, for 25 total IDs.
- Same historical performance job: 500 synthetic policies, p95 0.8397 ms and 2,573 policies/sec. These are environment-scoped microbenchmarks.
- CLI supports text, JSON and SARIF 2.1.0 findings and CI-friendly exits; Code Scanning integration is a capability, not evidence of a deployed account control.

## REPRODUCTION

- git checkout 229605c9c53068f4c0d7116d67554d19afe30183
- Install the documented development extras and run python -m pytest tests/ -q using the cited Linux CI configuration.
- A different platform or dependency set may produce different counts/coverage. This poster is not a promise about the latest main.

Dated tests and committed fixtures do not establish universal detection, production deployment or an SLO.